

# Issues — Open Workable Items

**Revision:** 132 **Last modified:** 2026-09-26T12:19:46Z **Ticket prefix:** BOB (operator-mandated, 2026-06-06) **Scope:** Open/active items only. Closed items migrate to Fixed.md.

Tracking: this file + Issues\_Summary.md are authoritative for open work. The SQLite single-source-of-truth + docs\_chain engine (BOB-010) is complete.

---

## BOB-008 — RuTracker automated login blocked by CAPTCHA

**Status:** Operator-blocked **Type:** Bug **Operator-Block-Details:** WHAT: Operator must physically drive the interactive CAPTCHA flow at /api/v1/auth/rutracker/captcha then /login once; no agent can solve a CAPTCHA (§11.4.52 honest operator\_attended boundary). WHY: Cookie-paste path and cookies-file autoload path were both offered and NOT chosen (operator decision 2026-08-26, §11.4.66); the interactive one-time CAPTCHA flow was selected instead, narrowing but not lifting the block. UNBLOCK: [A] Operator drives the interactive CAPTCHA+login flow once; resulting bb\_session verified PERSISTED and verified USED by a subsequent search – CHOSEN path (recurs periodically as the session expires, cost accepted). [B] Operator provides a pre-obtained cookie via paste – considered, NOT chosen. [C] Operator maintains a per-tracker cookies-file for autoload – considered, NOT chosen. WHO: Operator (milosvasic)

**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): COMPLETE THE CAPTCHA FLOW ONCE**

Session establishment path is DECIDED: the operator drives the interactive CAPTCHA flow at /api/v1/auth/rutracker/captcha then /login once, and the proxy stores the resulting bb\_session. The cookie-paste path and the cookies-file autoload path were both offered and NOT chosen. THE BLOCK NARROWS BUT DOES NOT LIFT: the operator must physically drive the flow — no agent can solve a CAPTCHA

(§11.4.52 honest operator\_attended boundary). AGENT PREP OWED BEFORE THE HAND-OFF, so the operator's single attempt succeeds rather than discovering a broken endpoint mid-flow: verify both endpoints are reachable and correctly wired end-to-end, verify the session is actually PERSISTED after a successful post (not merely accepted), and verify a stored session is actually USED by a subsequent search. Honest limitation to state up front: a stored bb\_session expires, so this path requires repeating — that cost was accepted with the decision.

This answer is recorded as consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions).

— prior item text follows —

RuTracker automated login blocked by CAPTCHA

## **BOB-065 — Lava P2: Egress diagnosis and VPN-host SOCKS routing (containers pkg/egress)**

**Status:** In progress **Type:** Task **Severity:** High

Lava P2: Egress diagnosis and VPN-host SOCKS routing (containers pkg/egress)

=== ROUND-2, 2026-09-25 — the egress/VPN mechanism ALREADY EXISTS (2026-07-01, commit be5062d + submodule cde354f/e273fd2/3a52825), this item's own tracker row was just never reconciled against it ===

Root cause of the confusion: TWO different “containers submodule” paths exist in this tree. constitution/submodules/containers (an unrelated nested dependency, no pkg/ dir) is NOT what this item or docs/PORTING-FROM-LAVA.md mean. The REAL one is the project-root submodules/containers (.gitmodules -> vasic-digital/Containers.git), which already has a complete, hardened, unit-tested pkg/egress (egress.go + egress\_test.go + wave20\_eg2hard\_test.go, 12/12 tests independently re-verified passing this round), and scripts/egress-via-

vpn.sh already exists and is already git-tracked (fail-loud on missing host, real direct-egress-IP probing, honest failure when no tunnel exists).

NEW THIS ROUND: tests/integration/test\_egress\_via\_vpn.py – scripts/egress-via-vpn.sh previously had no dedicated test (only a bare `bash -n` cited in its own commit). Adds 7 tests covering presence/exec-bit/syntax/usage/fail-loud-on-missing-host/fail-honest-on-dead-tunnel/real-direct-probe, plus the item’s own exact acceptance criterion as an honestly `@pytest.mark.skipif-gated` test (SKIP: no VPN host configured, §11.4.3) – ready to run unmodified the moment BOBA\_VPN\_HOST is configured. Independently re-verified: 6 passed, 1 honestly skipped.

REMAINING WORK: (1) an operator-provisioned, SSH-reachable VPN host set via BOBA\_VPN\_HOST; (2) running the skipped test (or scripts/egress-via-vpn.sh `diagnose <known-blocked-tracker>`) against it to produce the item’s own exact acceptance evidence (via-proxy egress IP != direct host IP AND a known-blocked tracker returns 200 via proxy). No tracker is currently blocked from this sandbox host, so “known-blocked” is necessarily operator/time-dependent and cannot be hardcoded.

EVIDENCE: docs/qa/BOB-065/investigation\_20260925.md.

## **BOB-066 — Lava P3:**

### **BOBA\_UPSTREAM\_PROXY in download-proxy + qBitTorrent-go + Jackett + compose env-forward**

**Status:** In progress **Type:** Task **Severity:** High

[Backfill from RD2-15/GA-05, audit doc 2026-08-08] Lava-porting finding P3 (Configurable outbound proxy in the services, Lava PLAYBOOK section 3). download-proxy (Python): `httpx/requests` honor HTTP\_PROXY/HTTPS\_PROXY/ALL\_PROXY/NO\_PROXY env natively — add an explicit BOBA\_UPSTREAM\_PROXY config that sets these for tracker-bound clients, with loopback bypass (`NO_PROXY=127.0.0.1,localhost,jackett`). qBitTorrent-go: set `http.Transport.Proxy` (socks5 native, remote DNS) from a BOBA\_UPSTREAM\_PROXY env — mirror Lava internal/`httpx/proxy.go`. Jackett: has a built-in proxy setting (configure via its API/ServerConfig). Deploy gotcha (port): the env must be FORWARDED into the containers (docker-compose.yml env / the boba-ctl deploy) — Lava bug was a

missing allow-list entry. Verify on distroless via podman inspect, not exec printenv. TDD: a test with a local proxy asserts the service tracker request traverses it; falsifiability: disable the wiring so the test fails. Source: docs/PORTING-FROM-LAVA.md. Per audit RD2-15 [P0]: Create tracked workable items (BOB-064..067) for the four Lava-porting findings, citing implementing commits as evidence, closed as Implemented.

## **BOB-068 — RD2-00: unattributed, unreviewed Auto-commit mechanism pushing to main**

**Status:** In progress **Type:** Bug **Severity:** High

RD2-00: unattributed, unreviewed Auto-commit mechanism pushing to main

[BOB-136 adoption audit 2026-08-21 -> In progress] Work landed but acceptance NOT met. a7e55f9 completed the Phase-1 investigation (no daemon; shared-checkout race confirmed) and 0972cbc added commit-push-all.sh -scope + challenge, described in its own message as an 'Interim tooling remedy for BOB-068 while the §11.4.179 architectural fix (task #67 proposal) is designed'. 35e53db is a DRAFT PROPOSAL only. The §11.4.179 clone-isolation fix is not landed, so the item stays open.

## **BOB-069 — RD2-40: §11.4.238 QA-discovery-channel ledger — ongoing coverage-escape backfill**

**Status:** In progress **Type:** Task **Severity:** High

RD2-40: §11.4.238 QA-discovery-channel ledger — ongoing coverage-escape backfill

[BOB-136 adoption audit 2026-08-21 -> In progress] a4173c8 stood up the ledger + 4 followups; 709b06c closed 2 Important review findings (CODEGRAPH-1.5.0-GITIGNORE entry, BOB-108 filed). The BOB-009/010 evidence\_path gap this item names as remaining open was closed

under BOB-086 (f78f383). NOT terminal by the item's own text: it is explicitly scoped 'P1-ongoing', with the full retroactive audit of the ~50 GA-NN/RD2-NN findings deliberately NOT attempted.

## **BOB-074 — RD2-07: DDoS-class testing fully absent from the mandated test-type matrix**

**Status:** In progress **Type:** Task **Severity:** Medium

RD2-07: DDoS-class testing fully absent from the mandated test-type matrix

[BOB-136 adoption audit 2026-08-21 -> In progress] ae2b5cb authored challenges/scripts/ddos\_resilience\_challenge.sh (424 lines, 3 public surfaces) + docs/testing/{ddos\_resilience,test\_type\_matrix}.md, so DDoS-class testing is no longer 'fully absent'. But of the three coverages this item's Fix line enumerates, a grep of the shipped challenge finds flood=2 hits, malformed=0, exhaust=0 — malformed-request-flood and resource-exhaustion-under-attack are not covered. 258b7db filed the 6 followups (BOB-109..114). Partial, not complete.

## **BOB-078 — RD2-11: Once identified, wire Auto-commit mechanism through §11.4.234 dedicated commit/push script OR retire it**

**Status:** Queued **Type:** Task **Severity:** High

[Backfill from GOVERNANCE\_AUDIT\_2026-08-08\_ROUND2.md RD2-11, P0] Once identified (RD2-10): either wire it through a real §11.4.234 dedicated commit/push script (with the hook-validation stages this project already has via .claude/settings.json PreToolUse guard, extended to a real pre-commit content check) or shut it down if it serves no purpose. Priority: P0. Blocked on RD2-10.

## **BOB-080 — RD2-13: Retroactive Fable-xhigh code review of the substantive Auto-commit diffs**

**Status:** Queued **Type:** Task **Severity:** High

[Backfill from GOVERNANCE\_AUDIT\_2026-08-08\_ROUND2.md RD2-13, P1] Retroactively run the mandatory independent Fable-xhigh code review (§11.4.125/§11.4.142/§11.4.209) against the substantive diffs the Auto-commit mechanism introduced (start.sh three new functions especially, since they have zero test coverage — see Root Cause 4 / RD2-24) — even though the changes already landed, a post-hoc review closes the governance gap and will surface RD2-24 (GA-27 missing tests) if not already caught. Priority: P1.

## **BOB-085 — RD2-18: Create top-level Boba proxy/merge-service v1.0.0 readiness ledger (closes GA-10)**

**Status:** Queued **Type:** Task **Severity:** Medium

[Backfill from GOVERNANCE\_AUDIT\_2026-08-08\_ROUND2.md RD2-18, P2 — closes GA-10] Create the top-level Boba (proxy/merge-service) v1.0.0 readiness ledger (GA-10) — dedupe with the browser\_extension existing one as the template. GA-10 evidence: only docs/RELEASE\_READINESS\_20260616.html/.md/.pdf (dated point-in-time snapshot) and the extension own ledger exist; no top-level proxy/merge-service ledger created. Priority: P2.

## **BOB-090 — RD2-25: HelixQA Challenge entry exercising all three start.sh subcommands end-to-end against real compose stack**

**Status:** In progress **Type:** Task **Severity:** Medium

RD2-25: HelixQA Challenge entry exercising all three start.sh subcommands end-to-end against real compose stack

[BOB-136 adoption audit 2026-08-21 -> In progress] a9366c9 bumped submodules/helixqa to HelixDevelopment/qa@00c5ca4 adding banks/boba-start-sh-reload.yaml (3 cases, all three subcommands). The bank EXISTS but has never been EXECUTED: the commit states honestly that the helixqa binary was not built in-session (§11.4.3 SKIP feature\_disabled\_by\_config) and 'live bin/helixqa list demo is deferred',

with only YAML-parse evidence captured. This item's acceptance is end-to-end execution against the real compose stack — artifact-class evidence cannot close a runtime-class acceptance (§11.4.226).

## **BOB-093 — RD2-28: Live compose bring-up + verify rutracker ReDoS regex bounds deployed to container (closes runtime half of GA-12)**

**Status:** In progress **Type:** Task **Severity:** High

RD2-28: Live compose bring-up + verify rutracker ReDoS regex bounds deployed to container (closes runtime half of GA-12)

[BOB-136 adoption audit 2026-08-21 -> In progress] 1c0389a proved 3 of the 4 sub-steps with strong runtime evidence: the bounded regex is confirmed in the DEPLOYED /config/qBittorrent/nova3/engines/rutracker.py inside the running container (sha256 76a6bd2e..), with a self-validated challenge + §11.4.115 RED (mutated unsafe form FAILs) and GREEN verdict JSON. The 4th sub-step is NOT met: 'capture timing of a large rutracker result page (<2s)' was not exercised — in docs/qa/BOB-093/live\_search\_smoke.txt rutracker returned status=empty, results\_count=0 in 164ms, so no large page was ever timed.

## **BOB-094 — RD2-29: Author tests/stress/test\_tracker\_fetch\_stress\_chaos.py with §11.4.85 fault injection**

**Status:** In progress **Type:** Task **Severity:** Medium

RD2-29: Author tests/stress/test\_tracker\_fetch\_stress\_chaos.py with §11.4.85 fault injection

[BOB-136 adoption audit 2026-08-21 -> In progress] The suite landed (test file at 4b7b21d, evidence + RED-on-mutated-classifier capture at f3ca131) with 9 test functions: 2 stress, 3 boundary, 3 chaos (network\_drop, midflight\_kill, input\_corruption), 1 category\_map. This item explicitly requires fault injection across process-kill, network-

fault AND resource-exhaustion. Only 2 of those 3 classes are present — there is no resource-exhaustion scenario in tests/stress/test\_tracker\_fetch\_stress\_chaos.py. Partial.

## **BOB-095 — RD2-30: Author tests/stress/test\_scheduler\_hooks\_sse\_stress\_chaos.py for Go-side triangle**

**Status:** In progress **Type:** Task **Severity:** Medium

RD2-30: Author tests/stress/test\_scheduler\_hooks\_sse\_stress\_chaos.py for Go-side triangle

[BOB-136 adoption audit 2026-08-21 -> In progress] d5c8c3e authored qBitTorrent-go/internal/service/sse\_broker\_stress\_chaos\_test.go (462 lines, 6 scenarios, 2 RED captures) and found+fixed a real double-unsubscribe ‘close of closed channel’ defect. But this item names a THREE-component triangle: sse\_broker.go + internal/api/hooks.go + internal/api/scheduler\_api.go. Only sse\_broker.go is covered — there is no stress\_chaos test anywhere under qBitTorrent-go/internal/api/. 1 of 3, partial.

## **BOB-097 — RD2-32: Author DDoS-class coverage for exposed download-proxy/merge endpoints (canonical impl of RD2-07)**

**Status:** In progress **Type:** Task **Severity:** Low

[Backfill from GOVERNANCE\_AUDIT\_2026-08-08\_ROUND2.md RD2-32, P3] Author DDoS-class coverage (RD2-07) for the exposed download-proxy/merge endpoints. Priority: P3.

## **BOB-101 — GA-19/RW-09: Is –profile go parity still a release goal? (gates RW-10..13) — OPERATOR-DECISION**

**Status:** Queued **Type:** Task **Severity:** High

**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): DEFER PAST v1.0.0**

Go --profile go parity remains a goal but is NO LONGER a v1.0.0 release blocker. RW-10..13 move to a post-1.0 milestone and stop gating the tag. Nothing advertised is removed, so §11.4.122 stays clean and no §11.4.90 Obsolete closure is warranted. The BOB-141 measured fact stands unchanged: the Go container's Dockerfile runs ONE binary binding only :7187; nothing binds :7186 or :7188 despite compose setting PROXY\_PORT/BRIDGE\_PORT. CLAUDE.md's port map already describes what the container ACTUALLY does and needs no amendment under this decision.

This answer is recorded as consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions).

— prior item text follows —

GA-19/RW-09: Is --profile go parity still a release goal? (gates RW-10..13)  
— OPERATOR-DECISION

**BOB-102 — RW-05: LAN-exposure threat model — bind tunnel 127.0.0.1 or keep 0.0.0.0? — OPERATOR-DECISION**

**Status:** In progress **Type:** Task **Severity:** Medium

**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): KEEP 0.0.0.0 + MANDATORY AUTH GUARD**

The tunnel STAYS LAN-reachable — no bind address changes to 127.0.0.1. The operator explicitly chose to preserve access from other devices on the network. THE DECISION CARRIES A BINDING OBLIGATION: a permanent §11.4.135 regression guard MUST land that FAILS THE BUILD if any LAN-reachable route ever stops demanding authentication. The operator accepted 0.0.0.0 ON THE CONDITION that guard exists — without it this decision is unprotected and the item is NOT closeable. Guard requirements: enumerate routes from the authoritative source (FastAPI app, Go handlers, boba-jackett) never a hand-maintained list; resolve real auth coverage not a grep for the string 'auth' (§11.4.201 real-condition); deliberately-public routes

exempt ONLY via a checked-in list with per-entry justification, enumerated as honest gaps never silent; golden-TRUE + golden-FALSE fixtures per §11.4.107(10).

This answer is recorded as consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions).

— prior item text follows —

RW-05: LAN-exposure threat model — bind tunnel 127.0.0.1 or keep 0.0.0.0? — OPERATOR-DECISION

## **BOB-104 — §11.4.238 followup: CodeGraph 1.5.0 nested-.gitignore regression challenge**

**Status:** In progress **Type:** Task **Severity:** Medium **Created-By:** Claude

Coverage-escape followup (docs/QA\_DISCOVERY\_LEDGER.md, BOB-075 agent-code-reading finding, commit e6162f7): CodeGraph 1.5.0 (up from documented 0.9.9) walked into nested-.gitignore-excluded frontend/node\_modules and extension/node\_modules (32,260 files / 514,456 nodes vs the 2026-06-06 baseline of 509 files / 8,906 nodes) instead of honoring frontend/.gitignore + extension/.gitignore per git check-ignore -v. Author a challenge (challenges/scripts/codegraph\_gitignore\_honor\_challenge.sh or equivalent, e.g. wrapping 'codegraph doctor -sniff-gitignore-honor' if that subcommand exists, else a real re-index + file-count assertion) with §11.4.115 RED\_MODE polarity: RED\_MODE=1 reproduces the blowup against the live nested-.gitignore tree, RED\_MODE=0 asserts the resync stays within the documented baseline order of magnitude. Full evidence: docs/codegraph/Status.md lines 91-118. UPSTREAM FILED 2026-08-18: real upstream repo is github.com/colbymchenry/codegraph (npm package @colbymchenry/codegraph, confirmed via package.json + gh repo view; NOT vasic-digital/codegraph, correcting this ledger's original assumption). Issue: <https://github.com/colbymchenry/codegraph/issues/1567> (full reproduction evidence: git check-ignore -v re-verified first-hand; two bounded synthetic repro attempts up to 63 nested .gitignore files / 960 files against the actual installed v1.5.0 binary did NOT reproduce the blowup in isolation – honest negative result, root cause not pinned to a specific line in either scanning implementation). Draft PR (diagnostic only, not a behavioral fix): <https://github.com/>

colbymchenry/codegraph/pull/1568 – adds a logDebug() call so a future report can confirm which of the two independent gitignore-respecting code paths (git-ls-files-based vs filesystem-walk fallback) actually ran. Both PRs/issue filed via SSH (Hard Stop #2) from a fork at github.com/milos85vasic/codegraph. Status: In-progress pending upstream maintainer triage/merge – boba-side closure of this item still needs the RED/GREEN challenge script (§11.4.115) authored per the original scope, independent of upstream’s response.

## **BOB-106 — §11.4.238 followup: §11.4.84 quiescence-check helper for the unattributed auto-commit path**

**Status:** In progress **Type:** Task **Severity:** Medium **Created-By:** Claude

§11.4.238 followup: §11.4.84 quiescence-check helper for the unattributed auto-commit path

=== ROUND-2 PROGRESS, 2026-08-21 (discovered + independently verified 2026-09-25 via BOB-238 investigation) ===

Already substantially implemented at commit 7b45113c6b03524d9c799bdd68496ec202575e4c: scripts/hooks/unattributed-commit-guard.sh (237 lines) + companion doc + a hermetic self-validated test (140 lines, golden-good/golden-bad/self-test per §11.4.107(10)). The guard’s own header carries an explicit, honest “WIRING (honest gap, §11.4.6)” section stating it is NOT yet invoked from scripts/pre\_build\_verification.sh or scripts/commit-push-all.sh. Confirmed via full-diff grep the guard’s name appears only in itself/its doc/its own test/BOB-162’s text – never inside either seam file.

REMAINING WORK: (1) actual wiring into one of the two seams; (2) the §11.4.224(E) brownfield-adoption operator decision – 14 pre-existing violating commits would immediately fail the seam as written today, so wiring it in un-gated would retroactively “break the build” on history nobody is fixing. This item is explicitly tracked as blocked on that same operator decision via sibling item BOB-162 (“this item is not closed until that answer is recorded”).

EVIDENCE: docs/qa/BOB-238/investigation\_20260925.md (full citation trail).

## **BOB-109 — BOB-074 followup: scaling-class test coverage absent from mandated test-type matrix**

**Status:** Ready for testing **Type:** Task **Severity:** Medium **Created-By:** Claude

docs/testing/test\_type\_matrix.md's §11.4.27 test-type audit found zero scaling-class coverage anywhere in the tree (no scaling-tagged directory, test file, or HelixQA bank distinguishes growing-dataset/tracker-count/concurrent-user scale-out from stress-under-burst). Scope at least one scaling dimension, e.g. tracker-count scale-out in merge search against challenges/helixqa-banks/boba-services.yaml's tracker set, or the qbittorrent-proxy-go –profile go swap, with a real measured baseline.

## **BOB-111 — BOB-074 followup: configure real rate limiting for boba's 3 public HTTP endpoints**

**Status:** In progress **Type:** Task **Severity:** High **Created-By:** Claude

Source inspection across the whole stack (2026-08-18) verified no rate-limit mechanism exists for :7185 (qBittorrent WebUI proxy), :7187 (merge search service), or :7189 (boba-jackett) – no slowapi/limiter/throttle import in download-proxy/src/, no rate-limit middleware in qBitTorrent-go/internal/middleware/ (only cors.go + logging.go) or internal/jackettapi/ (only auth/cors middleware tests, no rate middleware), and no nginx/reverse-proxy service in docker-compose.yml. Candidate remediations documented in docs/testing/ddos\_resilience.md: nginx-in-container reverse proxy with limit\_req\_zone (most portable, adds a container); a FastAPI slowapi dependency for the merge-search service; a Gin rate-limit middleware for boba-jackett following the existing internal/middleware/ pattern. qBittorrent's own WebUI bandwidth-shaping settings were NOT verified to cover request-rate (only bandwidth) – do not assume they close this gap without checking.

## **BOB-121 — External watchdog for the forced-logout architectural gap (task #85, incident #3)**

**Status:** Ready for testing **Type:** Task **Severity:** Important **Created-By:** Claude

Phase 1 design-only proposal: the BOB-116/task-77 resource-pressure preventive systemd –user timer runs inside user@1000.service, the exact pool it monitors, so it cannot fire when that pool dies (proven by incident #3, docs/qa/BOB-120/, 22:42+22:57 fires then blocked 23:45:49-23:49:00). Recommends Option B (user crontab reusing pre-existing crond.service in system.slice, no new root service) kept alongside the existing timer, with Option A (new root-owned systemd unit) as escalation path if Phase 1.5 live cron/cgroup verification is adverse. Proposal: docs/proposals/external-watchdog-for-forced-logout-architectural-gap.md. Operator decision required per §11.4.66 before any implementation – NOT implemented in this task.

**Progress 2026-08-21:** Flight recorder built, installed, and recording. First finding: NOTHING was watching at all — the root watchdog is LoadState=not-found and the BOB-116 user timer inactive. The blocking spike REFUTED the proposal's rationale while confirming its conclusion: this vixie-cron does invoke pam\_systemd so the tick lands in session-N.scope, but that scope is a SIBLING of user@1000.service, and the real incident killed exactly one unit (73 'user@1000.service: Killing process' lines while session-18.scope merely deactivated). So the recorder does not need to survive — its SCHEDULER does, and crond in system.slice survived all seven incidents. Captures the pre-event memory/PSI/thread ramp that nothing post-hoc can recover, plus boot id, the gap itself, unit start timestamp, cgroup pids, and OOM cgroup attribution. Evidence: 5 records under real cron at exact 60s spacing; a staged analogue on a DISPOSABLE unit reaching 'VERDICT: SESSION TEARDOWN'; golden-good against the REAL BOB-120 log giving the correct diagnosis (k\_unit\_kill=1, k\_oom=0); healthy-host quiet under load 8.15. NOT CLOSED — two operator decisions are owed: whether to keep it installed (one crontab line, zero signals, zero power verbs, 32K, reversible via uninstall.sh), and the root system.slice watchdog which is written but needs one su. UNTESTED AGAINST A REAL FORCED LOGOUT: survival is inferred from cgroup topology, not observed, and it does NOT hold against a whole-slice sweep or KillUserProcesses=yes. ## BOB-162 — Two new guards exist but no seam invokes them — plus the brownfield adoption decision the commit guard needs

**Status:** Queued **Type:** Task **Severity:** Medium **Created-By:** BOB-106/  
BOB-107 remediation, residual

**Reported-Via:** §11.4.202 reporting directive task on  
2026-08-21T19:35:02Z **Reported-By:** BOB-106/BOB-107 remediation,  
residual

**What (the report, verbatim):** The TESTS for both guards are now executed: pre-build invariant 30's glob was extended from tests/unit + tests/pre\_build to also cover tests/hooks. MEASURED before/after: the glob expanded to 27 suites with 0 under tests/hooks while 3 existed there; it now expands to 30 with 3 under tests/hooks. All three pass.

But the GUARDS themselves are still invoked by nothing.

check-brief-inputs.sh is honestly conductor-run rather than automatic: a brief's required-input list lives in free-form prose that the Agent tool's structured input does not expose, so an automatic prompt-scraping gate would itself be an unproven pattern-match. Its seam is the dispatch procedure, and that is a documentation + habit change, not a hook.

unattributed-commit-guard.sh is different and is why this item exists. Run against real history it names 14 violating commits since the last tag (and 21 bare Auto-commit subjects exist across all refs). Wiring it into the pre-build or commit seam AS-IS would therefore refuse every commit immediately, on pre-existing debt nobody can fix in the moment.

That is precisely the 11.4.224(E) brownfield-adoption shape, and 11.4.66/11.4.122 put the choice with the operator, not with an agent inventing a ratchet. The options, stated so the decision is a decision and not a default: (a) immediate hard floor – the seam refuses until all 14 are attributed; (b) one-time monotone-decrease ratchet (the 11.4.135 pattern) – snapshot 14 as the baseline, the count may fall and may never rise, so day one is green and the disease cannot spread; (c) changed-commits-only – gate only commits created from now on, with a scheduled deadline for the historical 14; (d) report-only for a stated period, then escalate.

Recommendation, with the reasoning rather than just the pick: (b). It is the pattern this constitution already uses for exactly this situation, it makes the debt visible and bounded immediately, and it cannot be

satisfied by deleting the guard's name (11.4.227 closes that gaming channel). But it is the operator's call and this item is not closed until that answer is recorded.

Honest boundary (11.4.6): this item does NOT claim the 14 commits are harmful in themselves – it claims their `ATTRIBUTION` is absent and that nothing currently prevents the 15th.

**Affected scope / file-scope manifest:** `scripts/hooks/unattributed-commit-guard.sh`; `scripts/hooks/check-brief-inputs.sh`; `scripts/pre_build_verification.sh`; `scripts/commit-push-all.sh`

**Reproduction / context:** Both guards run correctly by hand and are covered by passing tests (9/9 and 15/15, each proven non-bluff against a no-op stub). Neither is invoked by `scripts/pre_build_verification.sh` or `scripts/commit-push-all.sh`, so neither exerts standing detection pressure (11.4.226: a guard with no execution seam is not coverage; registration is not coverage).

**Acceptance criteria:** Each guard is invoked by a named seam, OR carries a registered deferral pointing at this item. For `unattributed-commit-guard.sh` specifically, the operator has answered the adoption question below and the answer is recorded as consumer `DATA` – never an invented ratchet.

**BOB-170 — Capture one quiescent GREEN run of the scaling growth gate, which has never executed under its own `loadavg<=0.75/cpu` precondition and has no scheduled window that would make it**

**Status:** Queued **Type:** Task **Severity:** Medium **Created-By:** Claude **Assigned-To:** Claude

WHAT. The BOB-109 scaling suite gates its two timing tests on `loadavg_1m/nproc <= 0.75` — on this 8-cpu host, a 1-minute load average at or below 6.0 — and SKIPS loudly otherwise. That gate is correct and was adopted for a good reason (§11.4.201(8)): the author validated a 2.10 growth-exponent threshold, then observed it FALSE-FAIL correct code at load 11.06 (baseline span 2.136), and at load 15-23

measured baseline spans of 2.358 against injected-cubic mutants at 2.278-2.331 — the signal is smaller than the noise and the two are not separable in either direction. Gating was the honest response.

THE PROBLEM. The gate has consequently NEVER RUN under its own precondition. Every recorded run today measured load 9.15-23; the independent reviewer measured 9.66 during review; the conductor measured 6.45 at its lowest. GREEN polarity WAS observed — at loads 9.4-11.6 (span 1.882) and in three stability runs (1.759/1.832/1.848) — but never once beneath the shipped ceiling. The author states this honestly as an inference from data rather than a run they can paste, and the reviewer confirmed the inference is sound (quiescence is strictly more favourable). Sound inference is still not an observed run.

WHY THAT MATTERS (§11.4.226). A registered, topology-present guard that never executes is indistinguishable from a guard that would fail if it did. Nothing currently ensures it ever runs: no freshness contract, no scheduled quiet-window invocation, no tracked item — which is precisely the unexecuted-standing-guard class §11.4.226 names, where registration gets treated as coverage while execution is nobody's job. The forensic precedent in that anchor is two standing guards that, when finally executed, immediately emitted latent FAILs.

ACCEPTANCE. (a) Execute both quiescence-gated timing tests on a host whose 1-minute loadavg is genuinely  $\leq 0.75/\text{cpu}$  — no agent fleet, no concurrent build — and capture the run as an artifact showing the resolved load reading alongside the measured span exponent, so the precondition is provable from the artifact and not asserted. (b) Record the observed GREEN polarity in the item and in the test source, replacing the current honest-inference note. (c) If the gate FAILS under genuine quiescence, that is the finding this item exists to surface, and it reopens the threshold-calibration question rather than being worked around. (d) Establish a freshness contract per §11.4.226: how stale a quiescent verdict may be before the gate counts as uncovered again, so this does not silently return to never-executing.

HONEST BOUNDARY. This item does not claim the gate is wrong. The evidence points the other way — quiescence is strictly more favourable than the loads where GREEN was already observed. It claims only that the run has not happened, and that an unexecuted guard cannot be cited as coverage.

PROVENANCE. Raised as IMPORTANT-2 by the independent Fable-substrate reviewer of the BOB-109 work, and independently corroborated: the reviewer verified the SKIP is loud and prints its resolved numbers, and confirmed the shipped tests do SKIP at today's load.

## **BOB-172 — rutracker search endpoint returns HTTP 403 with Cloudflare challenge markers and zero login markers, so one of three merge-search trackers silently contributes no results**

**Status:** Operator-blocked **Type:** Bug **Operator-Block-Details:** WHAT: Choose how the merge service reaches rutracker for SEARCH (not just login) given real-time re-verified 2026-09-25: GET /forum/tracker.php?nm=... returns 403 with cf-mitigated: challenge, zero login markers, in ~21-27ms – Cloudflare's edge decides before serving content, before any JS challenge runs. WHY: Attempted: (a) full realistic Chrome-header-set request vs the merge service's bare default request – identical 403 in ~21ms, ruling out header tuning; (b) live-probed all 3 configured rutracker mirrors – rutracker.org and rutracker.net both cf-mitigated:challenge, rutracker.nl fails TLS verification entirely; (c) no code path can solve a Cloudflare edge-layer challenge without external infrastructure or a supplied clearance token – changing shipped capability, needing §11.4.122 operator sign-off. UNBLOCK: Operator picks ONE: [1] Deploy a challenge-solving service (FlareSolvrr or equivalent) and route the rutracker search GET through it – not deployed today, same class of gap as kinozal/BOB-235; [2] Accept a supplied cf\_clearance cookie – RUTRACKER\_COOKIES already forwards supplied cookies but the code only checks for bb\_session, never cf\_clearance (the actual token this wall checks) – would need a small code change plus an operator refresh cadence via the existing scripts/load-tracker-cookies.sh pattern; [3] Route rutracker searches through Jackett's own rutracker indexer if its scraper has a working bypass – unverified, needs a separate boba-jackett indexer-health check; [4] Mark rutracker SEARCH unsupported per §11.4.90/BOB-172 acceptance(d) – README.md:167 still lists RuTracker with no caveat, unlike kickass/eztv which already carry this exact honest-capability-boundary treatment in docs/MERGE\_SEARCH\_DIAGNOSTICS.md. WHO: repository operator UNBLOCK: Operator picks ONE: [1] Deploy a challenge-solving service (FlareSolvrr or equivalent) and route the

rutracker search GET through it; [2] Accept a supplied cf\_clearance cookie (RUTRACKER\_COOKIES already forwards supplied cookies but only checks bb\_session, never cf\_clearance); [3] Route rutracker searches through Jackett's own rutracker indexer if its scraper has a working bypass; [4] Mark rutracker SEARCH unsupported per §11.4.90/BOB-172 acceptance(d) **Severity: High Created-By: Claude Assigned-To: Claude**

WHAT. The rutracker SEARCH endpoint is refused by bot protection while the site itself is fully reachable. Measured unauthenticated 2026-08-21 (no cookie file read, no credential value in any artifact — §11.4.10):

GET /forum/index.php -> 200, 96283 B,

, challenge markers 0 GET /forum/tracker.php?nm=debian -> 403, 5351 B, challenge markers 1, LOGIN markers 0, trs-tr- 0

The zero login markers are the load-bearing detail: the server is not asking us to authenticate, it is refusing the request before authentication is considered. Supplying valid credentials or a fresh cookie jar therefore does NOT address this.

WHY IT MATTERS. rutracker is one of the three trackers the merge service fans a query across (with kinozal and nnmclub). A 403 on its search path means it contributes nothing to every merged result set, silently — the fan-out still ‘succeeds’, it just returns one fewer tracker’s worth of results. From a user’s seat this looks like thin results, not an outage.

IT EXPLAINS TWO PREVIOUSLY-UNEXPLAINED OBSERVATIONS. docs/qa/BOB-093/live\_search\_smoke.txt records rutracker returning status=empty, results\_count=0 in 164ms, and the BOB-136 adoption audit reached the same observation independently. Both recorded the symptom; neither had the cause. 164ms is far too fast for a real search across a remote forum and is exactly what an immediate 403 costs.

IT ALSO BLOCKS BOB-093’s FOURTH SUB-STEP. That item requires timing a large rutracker result page under 2s. No large page has ever been obtained, and this is why. That sub-step is not merely waiting on credentials, as previously assumed — it is unmeetable until the 403 is resolved.

PROVENANCE, INCLUDING A CORRECTION I MADE MID-INVESTIGATION (§11.4.199). An independent reviewer reported a Cloudflare challenge served to curl even with cookies. Verifying, I

probed index.php, got a clean 200 with no challenge markers, and was one step from recording their claim as REFUTED. That would have been wrong for a textbook reason: index.php is not the search path, so my probe never reached the precondition, and a repro that misses the precondition proves nothing — it is not evidence of absence. Probing the actual search endpoint reproduced it immediately. The reviewer was substantially right; my probe was aimed at the wrong endpoint. Recorded because the near-miss is the instructive part, and because the two probes TOGETHER give a sharper result than either the original claim or my near-refutation: not ‘rutracker is behind Cloudflare’ (the index is open), but ‘the SEARCH endpoint specifically is refused’.

ACCEPTANCE. (a) Determine whether the 403 is permanent policy, rate/reputation-based, or triggered by a client signature the plugin can legitimately present (user-agent, header order, TLS fingerprint) — by measurement, not assumption, and WITHOUT evasion techniques that would violate the site’s terms. (b) Whatever the outcome, the failure must become LOUD: a tracker returning 403 must be reported as a tracker ERROR in the merge result, never folded into ‘empty’ — a silent contributor is the §11.4.201(6) false-null at the product layer, and it is what let this sit unexplained across two separate investigations. (c) A test asserting that a 403 from any tracker surfaces as an error and not as zero results, with a paired §1.1 mutation. (d) If the endpoint is genuinely unavailable to us, record that as an honest capability boundary (§11.4.112) and stop advertising rutracker as a live search source until it is — including in the README and the merge-service docs.

HONEST BOUNDARY. Measured from ONE host, ONE time, UNAUTHENTICATED. Whether an authenticated session with a browser-like client succeeds was NOT tested and must not be assumed either way. The finding is that the current code path gets a 403; it is not a claim about what every client would get.

## **BOB-184 — Icon-glyph controls are unverified for non-text contrast because neither contrast oracle can measure them**

**Status:** Queued **Type:** Task **Severity:** Medium **Created-By:** Claude  
**Assigned-To:** Claude

Three icon-glyph controls (.bridge-retry, .theme-toggle, .caret) render text made of non-BMP code points. axe-core declines to decide their contrast, reporting them under the incomplete channel with messageKey nonBmp and resolving NEITHER fgColor NOR bgColor, so the Python recomputation in docs/qa/BOB-164/axe\_contrast\_scan.py cannot decide either: 40 such nodes across 16 palette x mode combinations. BOB-164 round 2 stopped them being scored as silent passes by naming them GLYPH\_UNMEASURED, printing them on every run and fencing them, so any NEW unmeasured glyph node blocks. What remains genuinely unproven is their contrast itself: as non-text user-interface components they owe 3:1 under WCAG SC 1.4.11, and no oracle in this repo measures that today. Acceptance: a measurement path that resolves the effective foreground and backdrop for glyph controls (for example reading getComputedStyle colour against the composited backdrop, or replacing the glyphs with inline SVG carrying explicit fill tokens), each of the three controls shown to clear 3:1 in all 16 palette x mode combinations, and the GLYPH\_UNMEASURED fence shrunk by exactly the nodes then proven.

## **BOB-185 — Rendered-DOM contrast oracle cannot see data-driven nodes, leaving badge and status pills arithmetic-only**

**Status:** Queued **Type:** Task **Severity:** Medium **Created-By:** Claude  
**Assigned-To:** Claude

docs/qa/BOB-164/axe\_contrast\_scan.py scans a static dist with no backend, so every node whose existence depends on fetched data is absent from the page it measures: the results table renders empty, so .type-badge and .quality-badge never appear, and the hooks list renders empty, so .status pills never appear. That is precisely why the BOB-164 round-1 regression went unseen in a rendered DOM even though it was scanned in all 16 themes, and it is why round 2 had to close the class in the arithmetic oracle instead. Those nodes are now covered by frontend/src/app/models/style-contrast.spec.ts, which extracts declared foreground-on-fill pairs from the stylesheets, but that is an ARITHMETIC claim about declared colour pairs, not a rendered-pixel one: it cannot see opacity applied by an ancestor, a composited backdrop, or a cascade this repo's static extractor does not model. Acceptance: the scan drives the dashboard with seeded fixture data (a stub backend, a route fixture, or an injected component harness) so the

badge and status nodes are present in the DOM, axe measures them directly, and a control needle proves the rendered oracle sees a seeded sub-floor badge before any clean result from it is believed.

## **BOB-188 — Gate invariant 17 runs a STALE TRACKED binary that structurally cannot see the violations it exists to catch**

**Status:** In progress **Type:** Bug

**OPERATOR DECISION (2026-08-26, §11.4.66 interactive clarification): UNTRACK THE BINARY — BUILD ON DEMAND**

§11.4.30 answer, recorded as consumer DATA: the compiled workable-items binary is NOT to be git-tracked. ‘Any build derivate which we can recreate by executing proper mechanism for generating MUST NOT be versioned’ applies without exception here. Keeping it tracked with only the invariant-52 fingerprint gate, and keeping it tracked with a commit-time rebuild, were both offered and NOT chosen. REQUIRED END STATE: the gate builds from source, or REFUSES HONESTLY when the Go toolchain is absent (§11.4.201(11) — probe the artifact through its real invocation path, never fake a pass, never silently fall back to a stale binary). Staleness becomes structurally impossible rather than merely detected. ACCEPTED COST: a fresh clone needs a Go toolchain before invariant 17 can run — already true for the qBitTorrent-go backend, so this adds no new host requirement. The invariant-52 fingerprint gate remains useful as defence-in-depth for as long as any binary exists on disk.

This answer is recorded as consumer DATA per §11.4.35 — it is the operator’s stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions).

— prior item text follows —

pre\_build\_verification.sh invariant 17 (CM-WORKABLE-ITEMS-VALIDATE) resolves its binary through the candidate loop at :534, whose FIRST entry is constitution/scripts/workable-items/bin/workable-items. That file is GIT-TRACKED (md5 17644a248363, identical to bin/workable-items-linux) and executable, so it WINS

resolution over the current untracked sibling constitution/scripts/workable-items/workable-items (md5 43376a6d0184). The tracked binary is STALE: it does not contain the guards its own source now has.

MEASURED, needle-proven, 2026-08-25. String presence in the tracked binary: “refusing to set terminal status” -> 0; “Issues-location item has TERMINAL status” -> 0; control needle from the SAME updateCmd, “at least one mutable field flag is required” -> 2 (so the instrument sees through that path and the zeros are real absences, not a blind read). The untracked sibling returns 1 / 1 / 2 for the same three queries. A check whose message string is absent from the binary cannot fire.

RUNTIME PROOF: the same injected violation (a row set to terminal status while current\_location=Issues) run through both binaries -> stale reports 1 violation (only the body\_md desync class), current reports 2 including the location-status class verbatim. This is exactly why the ten BOB-166 rows (BOB-087/129/131/144/145/146/148/153/155/157) survived undetected: the gate that was supposed to catch them was running a binary structurally incapable of seeing them.

The 11.4.108 SOURCE->ARTIFACT gap: source correct, artifact stale, every gate reading the artifact reports green. This is the THIRD instance of that class found in one session, alongside BOB-169 (a charset gate that never opened a file) and BOB-183 (a served bundle five days older than its sources).

COMPOUNDING: the comment at :519-523 directly above the loop asserts “The naive bin/workable-items path never existed in this checkout (bin/ is a gitignored local build-output dir nothing ever populated)”. That statement is now FALSE - bin/ holds two tracked binaries. A stale comment asserting the absence of the very file that now shadows resolution is how this stayed invisible.

Also an 11.4.30 question the operator owns: bin/workable-items and bin/workable-items-linux are VERSIONED BUILD ARTIFACTS in a constitution submodule that is inherited by reference by every consumer, so every consumer inherits whichever binary was last committed. Flagged independently by two separate agents this session.

ACCEPTANCE: (a) resolution must never prefer a stale artifact over a current one - either the tracked binaries are removed and resolution falls through to build-on-demand, or a freshness check refuses a binary older than its sources (see the BOB-183 fingerprint gate for a working pattern); (b) the false comment at :519-523 corrected; (c) a paired 1.1 mutation proving the new refusal fires, plus a negative control proving

a genuinely fresh binary still passes so the fix is not an 11.4.201(1) false-positive refusal; (d) the 11.4.30 tracked-binary decision recorded as operator DATA. Discovered out-of-band during BOB-166 remediation - a 11.4.238 coverage escape in its own right.

## **BOB-191 — Fail-open scanner is a MATCHER hole blind to 5 enumerated languages (Go/Rust/Ruby/C/...) — enumerated-but-unanalysable prints PASS instead of SKIP (§11.4.201(6))**

**Status:** Queued **Type:** Bug

WHAT: the §11.4.252 fail-open scan reports 0 hits for qBitTorrent-go, and that zero is NOT evidence. The triage agent ran control needles through the scanner's own path per §11.4.201(7)(b): a Python 'except Exception: pass' needle was SEEN, a TypeScript 'catch (e) {}' needle was SEEN (so frontend/src's zero IS a real zero), but a Go empty-'if err != nil {}' needle was NOT SEEN. An instrument that cannot see the idiom returns the same quiet zero as a clean tree, and only one of those is honest. DISTINCT FROM BOB-189, deliberately not merged with it per §11.4.214: BOB-189 is a false MATCH (fail-closed guards reported as fail-open); this is a false NULL (an entire language unscanned). Same scanner, opposite failure directions, different fixes - merging them would hide one behind the other. IMPACT: Go is the language of qbittorrent-proxy-go and boba-jackett (port 7189, which owns encrypted tracker credentials), so the unscanned surface is exactly where §11.4.252's credential-plus-mutation combination is most likely. Nobody has assessed it; the dashboard says clean. ACCEPTANCE: the scanner grows a Go arm covering the empty-err-block and swallowed-error idioms, its needle is SEEN through the real path, qBitTorrent-go's result is re-derived, and every finding is triaged as this Python/TS pass was. Until then qBitTorrent-go's fail-open posture is UNKNOWN and must be reported as UNKNOWN, never as 0.

=== ROUND-2 INVESTIGATION, MEASURED 2026-08-26 — THE FILED TITLE WAS TOO NARROW (§11.4.6) ===

The live scanner is constitution/scripts/gates/cm\_dangerous\_combination\_fail\_closed.sh, driven per-root by invariant 39 at scripts/pre\_build\_verification.sh:1481-1544. (scripts/

pre\_build/check\_cm\_no\_fail\_open\_skip.sh has NEVER existed on any branch — it exists only in an uncommitted worktree. Any citation of that path is citing a file that is not there.)

IT IS A WEAK-MATCHER DEFECT, NOT A SCOPE HOLE. Line :243 sets exts="py go rs c cc cpp h hpp java cs js ts jsx tsx php rb" — .go IS enumerated. But line :537 gates the Python ast analyser on case "\$f" in \*.py), so every non-Python file falls through to just two text matchers (:772 empty catch (...) {, :794 credential = x || "literal"). Go has no catch keyword, so neither matcher CAN fire on Go by construction.

NEEDLE TEST, BOTH ARMS (planted / rc / result): Python 2 / 1 / SEEN · TypeScript 1 / 1 / SEEN · Java 1 / 1 / SEEN · **Go 6 / 0 / NOT SEEN — PASS** · Rust 2 / 0 / NOT SEEN · Ruby 1 / 0 / NOT SEEN · C 2 / 0 / NOT SEEN. Go is ONE OF FIVE BLIND EXTENSIONS, not a special case. The Go needle is real code: go build rc=0, go vet rc=0, gofmt -e clean.

THE DECISIVE DISCRIMINATOR — same bytes, extension changed: .zig (NOT enumerated) → "SKIP — topology\_unsupported"; .go (enumerated) → "PASS". The gate ALREADY OWNS an honest-blindness mechanism and it works correctly; Go routes around it precisely BY BEING ENUMERATED. A scope hole announces itself; this matcher hole prints green. That makes it the worse defect and is why the corrected title leads with it.

QUANTIFIED SURFACE (exclusions stated, §11.4.224(E)): using the scanner's OWN prune list and nothing added — 106 .go files / 20,389 LOC (52 production files / 6,858 LOC). WITH and WITHOUT exclusions the count is 106 == 106; no vendored tree exists, so no unstated exclusion could manufacture a clean number. qBitTorrent-go holds 106 blind files and 0 analysable files — 100% blind — yet invariant 39 counts it among "5 first-party source root(s)" reported clean.

DEFECTS THE BLINDNESS HID → filed as BOB-204 (credential DELETE returns unconditional 204 while the .env plaintext delete error is discarded; plus the env\_write\_failed\_db\_rolled\_back code asserting an unconfirmed rollback). SEPARATE SCOPE HOLE → filed as BOB-205 (cmd/boba-ctl, 947 LOC orchestrator, absent from DANGER\_ROOTS entirely). Distinct-but-similar per §11.4.214, deliberately not merged.

GOLDEN-FALSE FIXTURE FOR ANY FUTURE GO ARM: internal/jacketapi/auth\_middleware.go:45-66 is correctly fail-CLOSED (constant-time compare, 401+return) — a Go arm MUST NOT flag it.

LOAD-BEARING §11.4.250 PREDICTION: bolting a naive Go regex arm on will IMMEDIATELY manufacture BOB-189-class false positives in Go — `if err != nil { return false }` in a Go validator is fail-CLOSED. Fixing this as layer N+1 reproduces BOB-189 in a new language. THEREFORE the remediation order is fixed: (1) analyser REGISTRY with an UNANALYSED verdict FIRST — extension→analyser map, unmapped extension reports UNANALYSED never silent PASS, which converts the false null into an honest gap and covers rust/ruby/C too; (2) only then a Go arm, call-site-aware from day one (go/ast, or adopt errcheck/staticcheck rather than hand-rolled regex), shipped with the auth\_middleware golden-FALSE.

ONE PRIMITIVE, TWO SYMPTOMS: the scanner classifies by local syntactic shape and never consults semantic role — BOB-189 ignores the CALLER's context (false match), BOB-191 searches for a shape from a DIFFERENT language family (false null). The gate's own header already concedes the primitive ("requires real data-flow analysis this gate CANNOT honestly claim"); what is missing is propagating that concession into PER-LANGUAGE honesty. Keep two tracker items.

INSTRUMENT BUG RECORDED, NOT HIDDEN (§11.4.201(12)): the investigation's first verdict extraction used `grep -oE 'PASS|FAIL|SKIP'`, which matched FAIL inside the gate's own name (...FAIL-CLOSED) and mislabelled three PASSes. Re-run keyed on exit code; the table above is the corrected run.

EVIDENCE: docs/qa/BOB-191/  
scanner\_blindness\_investigation\_20260826.md (255 lines, §11.4.44 header). No source, gate, or config modified by the investigation.

=== ROUND-3 PARTIAL FIX, MEASURED 2026-09-25 — STEP (1) OF THE ROUND-2 REMEDIATION ORDER LANDED; STEP (2) STILL OPEN, ACCEPTANCE NOT YET MET ===

Per the round-2 remediation order, step (1) — the analyser REGISTRY with an honest UNANALYSED verdict — is now implemented and independently re-verified (conductor re-ran the mutation suite from a clean shell, 206/206 green). Step (2) — a real semantic Go arm — is DELIBERATELY DEFERRED, so this item stays Queued: the ACCEPTANCE criterion above ("its needle is SEEN through the real path") is still unmet for Go/Rust/Ruby/C.

CORRECTION TO ROUND-2's OWN FIGURE (§11.4.6, re-verified live, not re-guessed): round-2 said "5 blind extensions (go/rs/rb/c/h)". Re-run live against all candidates this round: C++ (.cpp, a genuine empty `catch()` `{}`) is SEEN — `rc=1 FAIL`, already correctly caught. It was never actually

blind; .h is content-ambiguous (same header extension serves both C and C++) and is not a distinct 5th case. **Exactly 4 languages are structurally blind: Go, Rust, Ruby, C.** This narrows, not widens, the round-2 figure.

WHAT LANDED (constitution/scripts/gates/cm\_dangerous\_combination\_fail\_closed.sh — a constitution-submodule file, inherited by reference; landing it for real still needs the submodule’s own §11.4.26 fetch/pull/push workflow, separate from boba’s commit path): - New DANGEROUS\_COMBO\_UNANALYSED\_EXT registry (default go rs rb c). Verdict now has 3 branches: real hits → FAIL (unchanged); zero hits + UNANALYSED files present → new honest △ NOTE – N file(s) UNANALYSED... + PASS (PARTIAL COVERAGE) (still exit 0, advisory — never blocks a build on an unanalysed language); zero hits + zero unanalysed → unchanged original clean-PASS text. - scripts/pre\_build\_verification.sh invariant 39 (boba-owned): fixed to read the UNANALYSED count unconditionally, not only on nonzero exit — otherwise a 100%-UNANALYSED root would still have silently printed “no fail-open anti-pattern across N clean roots” with the caller never seeing the NOTE. - Mutation test extended with 17 new assertions covering Go/Rust/Ruby/C UNANALYSED-branch RED/GREEN, a C++ negative control (still caught, never marked UNANALYSED — the registry must not swallow a working extension), a clean-root negative control, and a mixed-real-hit-not-masked control. Full suite 206/206 (189 pre-existing + 17 new), independently re-run by the conductor from a clean shell.

LIVE FULL-REPO RESCAN RESULT (real DANGER\_ROOTS, this round): Python backlog unchanged at 59 hits (download-proxy/src:25, plugins:32, scripts:2 — pre-existing, out of scope, advisory since 2026-08-20). **New honest signal: 121 files now reported UNANALYSED** (qBitTorrent-go:117, cmd/boba-ctl:4 — BOB-205’s scope hole now visibly folded into the same honest-gap mechanism) instead of silently counting toward “clean.” Zero new FAIL findings in Go — by design; a real Go checker needs call-site-aware semantic analysis, still deferred.

WHY STEP (2) STAYS DEFERRED, NOT A REGRESSION: the round-2 §11.4.250 PREDICTION stands unrefuted — a naive Go regex arm would immediately flag internal/jackettapi/auth\_middleware.go:45-66 (the golden-FALSE fixture) as a BOB-189-class false positive. A real arm needs go/ast or an adopted tool (errcheck/staticcheck), shipped WITH that golden-FALSE passing, before it can fire.

REMAINING WORK TO CLOSE THIS ITEM: implement the Go semantic arm (go/ast-based or errcheck/staticcheck-adopted) covering the empty-err-block and swallowed-error idioms, verified against the auth\_middleware.go golden-FALSE fixture, re-derive qBitTorrent-go's real result (currently UNKNOWN, honestly reported as such), and triage every real finding as the Python/TS pass already is. Rust/Ruby/C have zero first-party files in boba's tree today (verified this round) so their own arms are lower priority until such files exist — the UNANALYSED registry already covers them honestly in the meantime.

EVIDENCE: docs/qa/BOB-191/closure\_evidence\_20260925.md (full RED/GREEN transcripts, the C++ correction with live proof, the live full-repo scan table, anti-bluff provenance). State left uncommitted by design (constitution-submodule files need the §11.4.26 workflow, not boba's commit-push-all.sh).

## **BOB-194 — Pre-build gates walk .claude/worktrees, so a stale agent worktree can fail the main build (§11.4.201(1))**

**Status:** In progress **Type:** Bug

WHAT: agent worktrees under .claude/worktrees/ are ephemeral copies pinned at arbitrary commits - never built, never shipped, deleted when the agent finishes. Pre-build gates that walk the tree with find(1) from the repo root descend into them anyway. MEASURED INSTANCE (2026-08-25): CM-GO-TOOLCHAIN-MATCHES-BUILDER FAILED the main build with exactly one finding, from .claude/worktrees/agent-afda1df906c537ab4 - a worktree 86 commits behind still carrying 'FROM golang:1.23-alpine' against a go.mod long since at 1.26.2. The main tree was CORRECT throughout. Per §11.4.201(1) a false-positive refusal is a FAIL-bluff of equal severity to a false pass: it blocks real work and teaches people to bypass the gate. FIXED FOR ONE GATE: '.claude' added to that gate's PRUNE\_DIRS with a deterministic §1.1 pair - a stale mismatch inside .claude/worktrees must NOT fail a healthy tree, the SAME mismatch outside it MUST still fail, so the prune cannot widen into blindness (§11.4.201(6)). Mutation verified: reverting the prune fails 2 checks. SURVEY, measured not inferred: 8 of 13 pre\_build gates walk the tree; only the fixed one prunes .claude. Gates using 'git ls-files' are structurally immune - worktrees are untracked. Empirically probed: check\_cm\_closure\_seam\_binds, check\_cm\_killpg\_pgid\_guard and check\_cm\_no\_production\_mutation\_residue all rc=0 with ZERO

worktree references - clean in practice today. UNMEASURED, not clean: check\_cm\_test\_mock\_pid\_explicit\_int and check\_cm\_test\_mock\_pid\_patched\_when\_real\_pid were not reached before the probe budget expired. HYPOTHESIS REFUTED, recorded so nobody re-walks it: an earlier revision of this item speculated that check\_cm\_plugin\_count's 90s timeout was caused by walking worktrees. It is NOT. That gate's find is scoped to \$PLUGINS\_DIR (check\_cm\_plugin\_count.sh:224), so worktrees are outside its walk entirely. Its slowness is real - still running past 54s on a re-measure - but has a different, still-unidentified cause and belongs to its own item, not this one. ACCEPTANCE: every tree-walking gate either prunes agent scratch or is proven immune by measurement, each with a paired mutation. NOTE the asymmetry that bounds the risk: a stale worktree can only ADD findings to a security-relevant scan (killpg, mutation-residue), never remove them - so the exposure is false refusal and eroded trust, not a missed defect.

## **BOB-211 — LATENT + OPERATOR-GATED: on a uid-flattening mount whose uid is not the operator, chown fails EPERM with no fstype-aware diagnosis, and fmask/dmask silently defeat the preserve\_mode 600 contract**

**Status:** Queued **Type:** Bug **Severity:** minor

STATUS: LATENT on this host (measured: all six declared locations sit on ONE btrfs mount, fully ownership-expressive) and OPERATOR-GATED for verification. Retained from the dismissed BOB-206 rather than discarded with it, because the scenario is well-founded elsewhere: the declared mount is a udisks auto-mounted REMOVABLE NVMe, so another operator's portable drive being exFAT or NTFS is entirely ordinary.

TWO RESIDUALS: (1) REPAIR-LAYER DIAGNOSIS. On a uid-flattening mount whose flattened uid is NOT the operator, probe\_location correctly REFUSES (verified: uid=0 and uid=100999 both refuse). But it then hands ownership\_repair.sh a chown that will return EPERM, and nothing in the repair path is fstype-aware — so the operator sees a permission failure whose real remedy is a REMOUNT OPTION, which no message says. Reasoned, NOT proven: the shim used to verify BOB-206 models the stat READ, not the chown WRITE, and cannot settle whether chown actually fails. (2) MODE CONTRACT. vfat flattens

MODE via fmask/dmask, so the `preserve_mode: true / 600` contract on `.env` and `config/boba.db` would be silently unenforceable there. §11.4.10-adjacent: a credential file believed to be 600 that is world-readable by mount option is a leak the mode check cannot see.

WHY OPERATOR-GATED: a genuine end-to-end RED needs a real uid-flattening mount. The privilege-free route is `bindfs -u` (FUSE; `fusermount` IS present and `user_allow_other` IS set) — but `bindfs` is ABSENT on this host, as are `mkfs.vfat` and `losetup`. So verification needs either a `bindfs` install or a privileged loopback mount. Neither was attempted (§11.4.21 — high-blast-radius host mutation is operator-gated).

ALSO RECORDED: NO test anywhere exercises a uid-flattening filesystem — `vfat/exfat/ntfs/flatten/loopback/mkfs/losetup/bindfs/fusermount` all measure 0 across the three ownership test files, needle-proven (`probe_location` = 3 hits through the same instrument).

ACCEPTANCE: (1) operator decides whether to install `bindfs` or provide a privileged loopback so the RED can be built; (2) if verified, the repair path gains fstype-aware diagnosis naming the remount remedy; (3) the mode contract either detects mode-flattening mounts and refuses, or documents honestly that it cannot be enforced there.

DISCOVERY CHANNEL (§11.4.238): retained residual from the BOB-206 verification stream.

## **BOB-219 — LIVE §11.4.65 sync violation: docs/guides/tracker-credentials.{html,pdf} exist on disk but are untracked and ignored, while their .md source IS tracked**

**Status:** In progress **Type:** Bug **Severity:** major

WHAT, conductor-verified: `docs/guides/tracker-credentials.md` is TRACKED. Its §11.4.65-mandated export twins `docs/guides/tracker-credentials.html` and `.pdf` both EXIST ON DISK, are NOT tracked, and ARE ignored — matched by the `.gitignore` *credentials* `deny-all` at :31. The `.md` is rescued by an explicit allowlist entry at :38; nobody added entries for the twins.

WHY IT IS A LIVE VIOLATION AND NOT A HYPOTHETICAL: §11.4.65 requires every in-scope Markdown document to carry synchronized .html/.pdf siblings, and §11.4.212 requires every §11.4.65-scope doc to be reachable from the README. Two artifacts that exist locally but can never be committed are, from any fresh clone, ABSENT — so every clone of this repository has a tracker-credentials guide with no exports, while the authoring host looks complete. The divergence is invisible on the machine that would notice it.

WHY NOBODY SAW IT: this is a §11.4.201(6) FALSE-NULL of the BOB-212 class. git status never listed the twins, so no gate and no author had a signal. The blind instrument and the clean tree return the identical quiet zero.

ANOTHER INSTANCE OF THE SAME MECHANISM, filed here rather than separately because it is one fix: docs/qa/BOB-124/evidence/loginctl\_user\_state.txt is swallowed by \*\_user\* at .gitignore:~55 and is therefore uncommitted §11.4.83 QA evidence. Its SIBLINGS IN THE SAME DIRECTORY — user1000\_grepped.log, user\_scope\_events\_head.log, user\_service\_lifecycle.log — ARE tracked, saved only by the robust glob negation !docs/qa/\*\*/\*log. That one file is lost purely because it is .txt rather than .log. The pattern is exact: robust glob negations hold; per-file and per-extension rescues leak.

ACCEPTANCE: (1) both twins become trackable and are committed alongside their .md; (2) the BOB-124 .txt evidence likewise; (3) whichever BOB-212 fix direction is chosen, it MUST cover these — a fix that closes the future-swallow while leaving these three artifacts permanently uncommittable has addressed the mechanism and not the damage; (4) a check that a tracked .md in §11.4.65 scope has COMMITTABLE twins, so this class cannot recur silently.

DISCOVERY CHANNEL (§11.4.238): found by the BOB-212 blast-radius sweep — and only on its SECOND pass. The first pass filtered by a source-extension set that omitted .pdf, which hid this finding entirely; the agent re-ran with no extension filter over all 420 non-artifact paths and recorded the blind spot rather than shipping the first number. Worth keeping: an extension allowlist is itself a false-null generator, which is the same shape as the defect being investigated.

=== ROUND-2 PARTIAL CLOSURE, MEASURED 2026-09-25 — criterion 1 already done, criterion 2 unsatisfiable, criteria 3+4 done ONLY for the .md-export-twin class ===

Independently re-verified via `git check-ignore -v` on all three named artifacts: CRITERION 1 (tracker-credentials.{html,pdf} twins committable) — ALREADY DONE, pre-dating this round: commit 9f6f517 already added `!docs/guides/tracker-credentials.{html,pdf}` rescue lines (`.gitignore:49-54`); both are tracked and clean. Nothing to do.

CRITERION 2 (BOB-124 `loginctl_user_state.txt` trackable) — CLOSED AS UNSATISFIABLE. The file does not exist on disk, has ZERO trace in `git log --all --diff-filter=A -- "*loginctl_user_state*"`, and is absent from the entire working tree. Its `.log` siblings in the same directory ARE tracked (rescued by the existing `!docs/qa/**/*.*.log` negation), confirming the file was lost purely by having a `.txt` extension, exactly as the original report claimed — but there is no recovery path and no legitimate way to “make it trackable” without fabricating QA evidence, which is itself an anti-bluff violation. This criterion is permanently closed, not deferred.

CRITERION 3 (general mechanism preventing recurrence) — PARTIALLY closed. A new guard (see criterion 4) closes the class criterion 1 exemplified: a TRACKED `.md` file whose §11.4.65 export twin is `gitignore`-swallowed. It does NOT close the class criterion 2 exemplified: a NON-`.md` QA-evidence file (any extension) swallowed by an unrelated `gitignore` pattern. Extending the existing `!docs/qa/**/*.*.log` negation to also cover `.txt` was concretely measured this round and PROVEN UNSAFE for this project: `.gitignore` documents `cookies_*.txt` as this repo’s own secret-file naming convention, and a scratch-tree experiment confirmed a `.txt`-wide rescue would also un-ignore `cookies_rutracker.txt` / `RUTRACKER_session.txt` / `my_password.txt` — real credential-shaped files already relying on that exact pattern staying broad. This candidate fix is now closed off with evidence rather than left for a future session to re-attempt and re-measure. THE REMAINING GAP: a general mechanism for “a QA-evidence file legitimately meant to be tracked gets silently swallowed by a broad secret-shaped-filename `gitignore` pattern, distinguished from an actual secret file” remains genuinely open — it needs a smarter signal than file extension (e.g. content-sniffing, or an explicit per-file allowlist-on-creation discipline) that this round did not attempt to design, since inventing one hastily risked exactly the credential-leak class the constraint exists to prevent.

CRITERION 4 (a check exists) — DONE for the `.md-export-twin` class. New gate `scripts/pre_build/check_md_export_twins_committable.sh` + self-validated test `tests/pre_build/test_check_md_export_twins_committable.sh` (7 arms: RED, GREEN, 2

golden-FALSE, fail-closed x3, real-repo run, §1.1 paired mutation — all independently re-run and confirmed passing by the conductor). Wired into scripts/pre\_build\_verification.sh as invariant 58/58 (CM-MD-EXPORT-TWINS-COMMITTABLE), mirroring the sibling CM-GITIGNORE-SWALLOW-GUARD (BOB-212) pattern exactly — BLOCKING, not advisory, since it is a pure tree-scan needing no live stack.

REMAINING WORK TO FULLY CLOSE THIS ITEM: design and implement the criterion-3 residual — a mechanism distinguishing “a legitimate QA-evidence file lost to a secret-shaped gitignore pattern” from “an actual secret correctly caught by that pattern” — without narrowing the existing credential-protecting globs. Until then this item stays Queued; criteria 1/2/4 are genuinely done, criterion 3 is genuinely partial.

EVIDENCE: docs/qa/BOB-219/closure\_evidence\_20260925.md (full command transcripts: before/after git check-ignore, the .txt-wide-rescue safety experiment, 7-arm test output, standalone gate invocation against the real repo).

## **BOB-231 — A gate asserting every executable a pre-build invariant invokes is itself tracked (BOB-227 criterion 2 follow-up)**

**Status:** Queued **Type:** Task **Severity:** Major **Created-By:** AI

BOB-227 measured 3 of 4 artifacts of the CM-LAN-ROUTES-AUTHENTICATED gate untracked in git; criterion 1 (commit them) was already resolved by an unrelated prior commit before this session, closed 2026-09-23. Criterion 2 was NOT addressed: ‘a gate asserting that every executable a pre-build invariant invokes is itself tracked’ – a general mechanism preventing this whole CLASS of defect (a pre-build gate’s own implementation files shipping untracked, invisible to a fresh clone, no committed baseline for round-over-round diffs) from recurring for ANY future gate, not merely this one. ACCEPTANCE: (1) enumerate every file path scripts/pre\_build\_verification.sh invokes (via bash/timeout/python3 calls to scripts under scripts/pre\_build/, plus every tests/pre\_build/.sh and tests/hooks/.sh it runs) – likely via a static grep/parse of pre\_build\_verification.sh itself, or a runtime trace; (2) assert every one of those paths is git-tracked (git ls-files –error-unmatch); (3) wire this as a new pre-build invariant so a future untracked gate implementation is caught immediately, not discovered

independently weeks later; (4) a RED test creating an untracked fake gate-invocation target and asserting the new check fails on it, GREEN once the mechanism exists and the fake target is either removed or tracked.

## **BOB-235 — Live kinozal credential test reports authenticated=False, status='empty', error=''** — cause UNKNOWN

**Status:** Operator-blocked **Type:** Bug **Operator-Block-Details:** WHAT: Choose how the merge service reaches Kinozal (kinozal.tv resolves to 127.0.0.1 here; kinozal.guru sits behind a Cloudflare challenge) WHY: Attempted: (a) diagnostics now surface the real failure (code half fixed + tested); (b) no code path can bypass a Cloudflare challenge or change host DNS; (c) picking a mirror, a challenge solver or dropping a tracker changes shipped capability and needs an operator decision (§11.4.122) UNBLOCK: Operator picks ONE: [1] KINOZAL\_MIRRORS=https://kinozal.guru in .env + ./start.sh --recreate; [2] change the roster primary host in trackers.py; [3] supply a cf\_clearance cookie / FlareSolvrr / Jackett kinozal indexer; [4] mark Kinozal unsupported (Obsolete, feature-removed per §11.4.90) WHO: repository operator **Created-By:** Claude

Live kinozal credential test reports authenticated=False, status='empty', error='' (found 2026-09-23). ROOT CAUSES (docs/qa/BOB-235/investigation\_20260923.md): (A) operator/environment: kinozal.tv publishes A record 127.0.0.1 (host, container, DoH Cloudflare+Google all agree; rutracker.org resolves normally as control), KINOZAL\_MIRRORS is empty so search.py falls back to kinozal.tv; the live mirror kinozal.guru answers every non-browser client with a Cloudflare 403 'Just a moment' challenge (login POST, curl, aiohttp, operator cookies with two user-agents; no cf\_clearance cookie; KINOZAL\_COOKIES is loaded into the container but no code reads it). (B) code defect FIXED under TDD (RED 2 failed/1 passed, GREEN 19 passed): \_search\_kinozal's except branch only logged and stashed no diagnostic, so the chip read empty with error=None; it now stashes error\_type + 'Kinozal request failed: '. Needs ./start.sh --reload-python to be live. Credential validity is UNKNOWN (no request ever reached a login endpoint) - do not rotate credentials on this evidence. Operator-Block-Details: WHAT: choose (1) reachable domain - set KINOZAL\_MIRRORS=https://kinozal.guru + ./start.sh --recreate, or change the roster primary in trackers.py; (2) how to pass the Cloudflare

challenge - FlareSolvrr (not deployed), cf\_clearance cookie + code that actually reads KINOZAL\_COOKIES, Jackett's kinozal indexer, or mark kinozal operator-blocked; (3) optionally re-export a kinozal-only cookie file. WHY: every agent-reachable path was exhausted - DNS, mirrors, login POST, cookies, env propagation all measured. UNBLOCK CONDITION: the live test authenticates or the operator marks kinozal unsupported. WHO: repository operator.

## **BOB-237 — CM-GATE-LEDGER-RATCHET**

**FAIL: constitution corpus has 414 unimplemented CM-\* gates against a checked-in baseline of 403 (§11.4.227(A))**

**Status:** Queued **Type:** Bug **Severity:** high **Created-By:** AI **Assigned-To:** AI

WHAT: CM-GATE-LEDGER-RATCHET (§11.4.227(A)) FAILED the pre-build sweep during this session's batch-15 commit attempt: unimplemented=414 exceeds the checked-in baseline=403 in constitution/scripts/gates/gate\_ledger\_baseline.txt. This is a HARD, blocking FAIL (unlike the other gate findings surfaced in the same sweep, which are all explicitly ADVISORY/non-blocking per §11.4.234).

INVESTIGATION (§11.4.102): the four newest anchors this session's constitution pull brought in (§11.4.268 tamper-evident evidence chain, §11.4.269 critic/consensus advisory-only ban, §11.4.270 dependency-existence-verdict register, §11.4.271 waiver mechanism) were checked FIRST as the likely cause, since they are the most recently landed (2026-08-26) and each names several recommended mechanism gates in its own text. RULED OUT: every one of those gates' names (CM-CRITIC-CONSENSUS-ADVISORY-ONLY, CM-DEPENDENCY-EXISTENCE-VERDICT-REGISTER, CM-EVIDENCE-CHAIN-ANCHOR-CATCHES-RECOMPUTE-AND-TRUNCATION, CM-EVIDENCE-CHAIN-DELETE-REORDER-DETECTED, CM-EVIDENCE-CHAIN-INCOMPLETE-VERIFICATION-REFUSES, CM-WAIVER-ROSTERED-EXPIRY-TRACKED) is already correctly registered DEFERRED against an OWED-GATE-NNN tracked item, and each anchor's own §11.4.227(B) propagation gate is IMPLEMENTED. So this batch of new anchors did NOT introduce the ratchet violation.

The full ledger run (docs/qa/BOB-237/unimplemented\_gates\_snapshot\_20260925.txt, 414 lines, captured verbatim from `bash constitution/scripts/gates/cm_gate_ledger_ratchet.sh`) shows the total current state is 414 UNIMPLEMENTED + 121 IMPLEMENTED + 73 DEFERRED. The checked-in baseline (403) was last legitimately bumped by commit 34e42f0 (“cite the §11.4.209 gate rename, bump baseline 397->403”) — some point after that, the unimplemented count grew to 414 (11 more) without a matching baseline bump or deferral registration for the newly-named gates, across one or more subsequent anchor-landing rounds in the constitution submodule. This is accumulated UNIVERSAL governance-corpus debt, not something introduced by any boba-side edit in this session (confirmed: `git diff eba38e8..HEAD -- constitution/scripts/gates/gate_ledger_baseline.txt` inside the constitution submodule is empty — the baseline file itself was never touched across the two merges this session performed).

WHY DEFERRED RATHER THAN FIXED HERE: identifying which of the 414 unimplemented names are the specific 11 that pushed past baseline, and then either implementing 11 gates’ worth of real UNIVERSAL gate-code or registering 11 proper OWED-GATE-NNN deferrals with tracked-item citations, is itself real engineering work scoped to the constitution submodule (universal, not project-specific per §11.4.17) — it is not a boba-project fix and doing it hastily mid-session, unrelated to this session’s actual mandate (Jackett incorporation + backlog triage), risks exactly the kind of rushed, unreviewed governance-corpus edit §11.4.209’s Fable-xhigh review requirement exists to prevent.

ACCEPTANCE: (1) a future session (or the constitution’s own maintainers) triages the 414-line snapshot against the 403 baseline to identify the specific unaccounted gate names; (2) each is either implemented, registered as a proper OWED-GATE-NNN deferral, or (if genuinely retired) cited in `constitution/scripts/gates/gate_ledger_removals.tsv`; (3) the constitution submodule’s baseline is re-bumped with a citation once accounted, following the same pattern as commit 34e42f0; (4) boba’s own pinned constitution pointer is then re-synced and this item closed with the passing CM-GATE-LEDGER-RATCHET re-run as evidence.

DISPOSITION FOR THIS SESSION’S COMMIT: per §11.4.234(D) (the commit/push mechanism MUST always be able to complete; a failing gate is skippable ONLY via an explicit recorded deferral flag, with the skip recorded in the commit message so the debt stays tracked, never forgotten), this session’s batch-15 commit used the sanctioned skip

(BOBA\_SYNC\_SKIP\_CI=1), citing this tracked item BOB-237, rather than silently bypassing or spending unbounded effort resolving an inherited universal-corpus debt mid-session.

DISCOVERY CHANNEL (§11.4.238): found by boba's own pre-build sweep (scripts/pre\_build\_verification.sh, invariant 38/57) during a routine session commit — the automated gate itself is the discoverer, exactly as §11.4.238 requires.

## **BOB-242 — Implement CM-SCRIPT-DOCS-SYNC (§11.4.18) and CM-DOC-REVISION-HEADER-PRESENT (§11.4.44) – the two gates BOB-223 found named-but-unimplemented and registered as deferrals**

**Status:** Queued **Type:** Task **Created-By:** Claude **Assigned-To:** Claude

BOB-223 closed the incentive inversion where writing a §11.4.18-mandated docs/scripts/.md companion doc tripped invariant 16 while the mandate requiring the doc to exist (CM-SCRIPT-DOCS-SYNC) has zero implementation, and the doc's required §11.4.44 revision header (CM-DOC-REVISION-HEADER-PRESENT) is likewise unenforced outside one unrelated ledger file. Both are now registered as explicit GATE-DEBT REGISTER deferrals in scripts/pre\_build\_verification.sh, satisfying §11.4.227(A)'s bar for now, but the underlying mandates remain unenforced. This item implements BOTH: (1) walk every .sh/.ba sh under scripts/, require a docs/scripts/.md companion (24 of 36 currently lack one per BOB-151's own count), verify same-commit-or-newer mtime per §11.4.18's literal text; (2) require every in-scope companion doc to carry **Revision:/Last modified:** per §11.4.44. Both need an operator brownfield-adoption decision (§11.4.224(E))/§11.4.66 – immediate hard floor vs. monotone-decrease ratchet vs. changed-files-only), a paired §1.1 mutation each, and – once landed – removal of both DEFERRED: lines from the GATE-DEBT REGISTER in scripts/pre\_build\_verification.sh. Duplicate-of/originating-from: BOB-223, BOB-151. Also recommend adding two rows to constitution/scripts/gates/gate\_ledger\_deferrals.tsv (the constitution submodule's own canonical §11.4.227(A) deferral ledger) once this new item's ID is known.

## **BOB-243 — CM-GITIGNORE-SWALLOW-GUARD: 4 first-party source files under .specify/extensions/superspec/ silently swallowed by .gitignore**

**Status:** Queued **Type:** Bug **Created-By:** Claude **Assigned-To:** Claude

Discovered by a full 58-invariant pre\_build\_verification.sh sweep (2026-09-25) run during BOB-223 closure verification: invariant 56 (CM-GITIGNORE-SWALLOW-GUARD, §11.4.201(6), BOB-212) reports 4 first-party source files silently ignored: .specify/extensions/superspec/scripts/e2e-agent-claude.sh, .specify/extensions/superspec/scripts/e2e-smoke.sh, .specify/extensions/superspec/scripts/validate-extension-metadata.py, .specify/extensions/superspec/scripts/validate-release-archive.py – all blocked by the broad .gitignore:218 rule ‘.specify/extensions/superspec/'. Unrelated to BOB-223's own scope; a genuinely new finding, not previously tracked. Remedy per the gate's own remediation text: either rename/relocate the files so no .gitignore rule matches them, or add an explicit ! negation for them in .gitignore, then re-run the guard. Investigate first per §11.4.6/§11.4.124 whether the broad .specify/extensions/superspec/ ignore rule was intentional (e.g. to exclude a vendored/generated subtree) before narrowing it, since a careless negation could re-expose something the rule was deliberately protecting.

## **BOB-246 — commit-push-all.sh: –scope flags placed after the commit message are silently ignored, falls back to git add -A**

**Status:** In progress **Type:** Bug **Severity:** Critical **Created-By:** AI **Assigned-To:** AI

Discovered 2026-09-25 by a subagent implementing 003-zero-shortcomings-audit Task 1, independently reproduced in isolation. scripts/commit-push-all.sh's argument parser stops reading flags at the first non-flag token; when –scope flags are placed AFTER the commit-message positional argument (exactly as tasks.md's own Step 5 template shows for every task in the 003-zero-shortcomings-audit plan, e.g. “bash scripts/commit-push-all.sh "" –scope ”), the –scope flags are silently swallowed as if they were part of the message, no error or warning is emitted, and the script falls through to its unconditional/

unscoped git add -A path. Real-world consequence (2026-09-25): following that exact template ordering caused a scoped Task-1 commit to instead sweep in 5 files – the intended 2, a sibling task's 2 legitimate-but-not-yet-reviewed files, and a DELIBERATELY-uncommitted, known-broken/hanging test file (tests/ddos/test\_sse\_stream\_stress\_chaos.py, see BOB-097 diary entry\_id=16) – and PUSH all of it to two remote git hosts before the mistake was caught. No data was lost, nothing was force-pushed, but a silent full-tree-sweep on a routine commit is a serious safety gap in a script this project's own constitution names as the ONLY sanctioned commit path. Root cause: the parser's flag/positional-arg interleaving logic assumes flags always precede the message and never validates that assumption or warns when scope flags appear post-message. Remediation: (1) make the parser accept –scope flags in ANY position relative to the message (getopts-style two-pass parsing, or explicit flag-then-positional-then-more-flags handling), OR (2) at minimum, detect scope-flag-shaped tokens appearing after the first positional argument and REFUSE with a loud error rather than silently falling back to git add -A – a parser that cannot tell 'no –scope given, unscoped commit intended' apart from '–scope given but in the wrong position' is itself a §11.4.201(1) false-negative-class defect. (3) Audit and fix tasks.md's own Step 5 example ordering across every task (flags before the message, matching the working pattern used successfully elsewhere this session) so the plan itself does not keep tripping this bug for every future task implementer.

## **BOB-247 — Zero-shortcomings audit: standing-check must re-verify closed items (SC-005)**

**Status:** Queued **Type:** Task **Severity:** Important **Created-By:** AI

**Reported-Via:** §11.4.202 reporting directive task on  
2026-09-26T08:51:37Z **Reported-By:** AI

**What (the report, verbatim):** Found by the final whole-branch review of feature 003: SC-005 is not met. The mechanism exists (verify-closure, risk order) but nothing drives it over closed items on a recurring basis.

**Affected scope / file-scope manifest:** scripts/  
zero\_shortcomings\_audit.sh cmd\_standing\_check; specs/003-zero-  
shortcomings-audit SC-005

**Reproduction / context:** Reintroduce a previously fixed defect whose closure evidence exists; standing-check reports only counts (backlog/gates/escapes) and never re-runs closed items' recorded commands, so the regression is not detected.

**Acceptance criteria:** standing-check (or a sibling recurring mode) periodically re-runs verify-closure over a risk-ordered sample of closed items and records any mismatch as a finding without blocking; a test reintroduces a fixed defect in a temp DB and proves it is flagged.

## **BOB-248 — Zero-shortcomings audit: deferred review follow-ups (FR-010/011/012, minor hardening)**

**Status:** Queued **Type:** Task **Severity:** Minor **Created-By:** AI

**Reported-Via:** §11.4.202 reporting directive task on  
2026-09-26T08:52:13Z **Reported-By:** AI

**What (the report, verbatim):** Deferred by ruling: FR-011  
audit\_dispatch\_bounded is defined but never called; FR-010 only  
checks one declared Test Type, not that every applicable type was used;  
FR-012 risk order ignores the severity column; blocked-surface trim()  
ignores tab/newline-only conditions and duplicate details rows double-  
print; redactor over-redacts ordinary text and misses db\_password =>  
x, mysql -pSECRET, URL-encoded values; BASH\_ENV can reach the  
fresh verify-closure process; the exit code 1 is shared between  
mismatch and usage/internal refusals (contract debt); the [59/59]  
stage's degraded WARN branch is proven at unit level only, never in a  
live sweep.

**Affected scope / file-scope manifest:** scripts/  
zero\_shortcomings\_audit.sh; specs/003-zero-shortcomings-audit

**Reproduction / context:** See final review of feature 003.

**Acceptance criteria:** Each listed follow-up is either implemented with  
a RED-first test or closed with an evidence-backed reason.

# BOB-249 — CM-BASH-UNIT-TESTS-EXECUTED fails: something rewrites tracked export twins while the bash suite runs

**Status:** Queued **Type:** Bug **Severity:** Important **Created-By:** AI

**Reported-Via:** §11.4.202 reporting directive bug on 2026-09-26T12:19:46Z **Reported-By:** AI

**What (the report, verbatim):** Found while running the deferred long gate after merging feature 003 (zero-shortcomings audit). Pre-existing: reproduced identically at the merge-base, so it is not caused by that feature. It keeps the long gate red independently of the separate gate-ledger debt (BOB-237), so BOBA\_SYNC\_SKIP\_CI=1 cannot be retired until both are fixed.

**Affected scope / file-scope manifest:** scripts/pre\_build\_verification.sh invariant 30 (CM-BASH-UNIT-TESTS-EXECUTED); the writer of docs/Issues., docs/Fixed., docs/\*\_Summary., README. and docs/qa/BOB-/closure\_evidence\_.docx export twins

**Reproduction / context:** Run 'ionice -c 3 nice -n 19 bash scripts/pre\_build\_verification.sh' on a clean tree. Invariant 30 FAILs: 'N tracked file(s) mtime-moved while the bash suite ran' and the rewritten files show as modified in git status (byte changes only in the generated .docx/.html/.pdf twins; the Markdown sources are unchanged). Measured 2026-09-26: at merge-base 120fd78 (old constitution pin 25980c1) 15 files moved (README, Fixed, Fixed\_Summary, Issues, Issues\_Summary twins); at main 88767fc 18 files moved (adds docx twins of several docs/qa closure evidence files and the quickstart evidence). Restoring the files with git checkout makes the tree clean again. Running six export-related tests from tests/unit one at a time (test\_docx\_export, test\_export\_pdf\_charset\_integrity, test\_export\_staleness\_oracle, test\_generate\_markdown\_exports\_path\_arg, test\_pre\_build\_workable\_items\_invariant, test\_update\_readme\_doc\_links\_no\_duplication) did NOT move the files, so the writer is UNCONFIRMED. Earlier commit ea8ffed documents a similar side effect attributed to workable-items-export.sh, which is a resemblance not a diagnosis.

**Acceptance criteria:** Root cause of the writer is identified with captured evidence (bisect the bash suite and the sweep stages that run before invariant 30, with a control needle proving the mtime

instrument sees a known write); the writer either stops touching tracked twins during the sweep or writes only when sources changed (idempotent, byte-stable output); a test fails against the current behaviour and passes after; a full pre\_build sweep on a clean tree leaves git status clean and invariant 30 PASS.